Cybersecurity Findings Report

From: William Moru
Title: Cybersecurity Engineer | Certified Ethical Hacker | Senior Software Tester (app security)
Date: 5th December 2024
To: Uganda National Examination Board,

Issue: UNEB E-PAY

Subject: Critical Security Concerns on UNEB E-PAY Platform (IP: 35.227.91.3)

Dear UNEB,

I am reaching out as a cybersecurity engineer with a professional obligation to notify organizations about potential vulnerabilities and risks that could compromise their systems and sensitive data. During my routine research and analysis of exposed public-facing systems, I came across security concerns related to the UNEB E-PAY platform hosted at **35.227.91.3**. These findings indicate the presence of vulnerabilities that may put the platform, its users, and sensitive data at risk.

Below are the detailed observations, implications, and recommended actions for your review:

---

1. System Overview

The IP address **35.227.91.3** is hosted on **Google Cloud Platform** in **North Charleston, United States**. It appears to serve the UNEB E-PAY platform, which facilitates payments for UNEB invoices via banks and mobile money.

The server operates on:

- **Operating System:** Ubuntu
- **Web Server Software:** Apache/2.4.18 (Ubuntu)
- **Ports Exposed:**
    - **80 (HTTP):** Insecure HTTP connection.
    - **443 (HTTPS):** Likely configured for secure connections, though unconfirmed.

The site utilizes various common web technologies such as Bootstrap, jQuery, Google Font API, and Osano for UI/UX functionality.

Evidence:



---

2. Key Findings

2.1. Outdated Apache Version

- **Apache/2.4.18** is outdated, it was released in **December 2015** and is no longer actively supported or maintained by the Apache Software Foundation. Running this version in a financial environment can pose severer security risks because:

1. **No Security Updates:** Outdated versions have many known unpatched vulnerabilities that attackers can exploit so easily.
2. **End of Support:** the outdated software may not support modern web standards or features of security and secure access.
3. **Known Vulnerabilities:** Many known security issues (e.g., CVEs) have been discovered since its release.
4. Exploits targeting this version directly can allow unauthorized access, denial of service, or code execution leading to financial loss, data breach, etc.

Evidence:



2.2. Lack of Secure HTTP Enforcement

- The server responds on port **80 (HTTP)** without automatically redirecting to HTTPS, leaving communications vulnerable to interception and tampering (e.g., **Man-in-the-Middle (MitM)** attacks).

Evidence:



2.3. Potential Vulnerable Dependencies

The platform uses several third-party libraries and frameworks, including:

- **Bootstrap, Font Awesome, jQuery, Modernizr, Osano**, and **particles.js**.
  Outdated versions of these libraries are frequently exploited by attackers. This may not be automatically exploitable but Serious monitoring of 3rd party libraries is recommended to avoid chain supply attacks

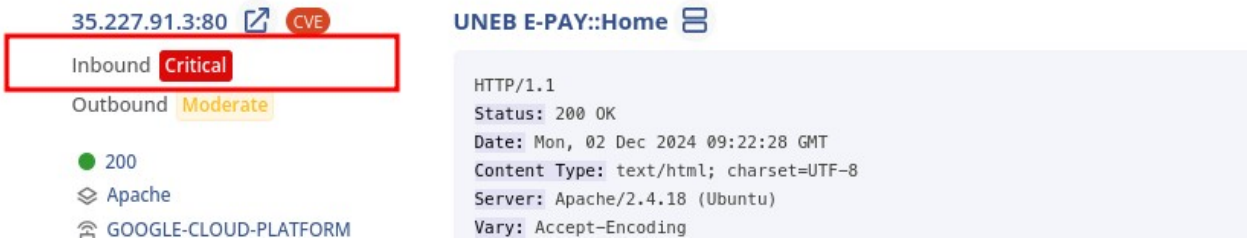
Evidence:



2.4. Critical Inbound Traffic Risks

- Analysis suggests **critical inbound threats**, potentially from malicious actors attempting to exploit vulnerabilities. Your system is too vulnerable and in a critical state. Serious attention is advised.

Evidence:



2.5. Missing Security Headers

Initial inspection indicates the absence of key security headers such as:

- **Content Security Policy (CSP)**
- **Strict-Transport-Security (HSTS)**
- **X-Frame-Options**
  These headers are critical to prevent attacks like clickjacking, XSS, and content injection. Advised to perform thorough security test on your systems facing the public.

---

3. Potential Implications of the findings

1. **Data Breach:** Sensitive user information, including payment details, could be intercepted or exfiltrated.
2. **Reputational Damage:** A security incident could lead to loss of trust from users and stakeholders.
3. **Financial Losses:** Successful exploitation may result in fraudulent transactions or legal penalties for non-compliance with security standards (e.g., GDPR, PCI DSS).
4. **Service Disruption:** Attackers could exploit vulnerabilities to launch denial-of-service (DoS) attacks, rendering the platform inaccessible.

---

4. Recommendations

Immediate Actions

1. **Update Software:**
   - Upgrade **Apache** to the latest supported version.
   - Update all third-party libraries and frameworks to their latest, secure versions.
2. **Enforce HTTPS:**
   - Redirect all HTTP traffic (port 80) to HTTPS (port 443) using **Strict-Transport-Security (HSTS)**.
   - Verify SSL/TLS certificate configurations to ensure strong encryption (e.g., TLS 1.2/1.3).
3. **Conduct Security Test:**
   - Do further security testing of your system

Medium-Term Actions

1. **Implement Web Application Firewall (WAF):**
   - Protect the application from malicious traffic and potential exploitation attempts.
2. **Add Security Headers:**
   - Configure **CSP, HSTS, X-Frame-Options,** and **X-Content-Type-Options** headers in the web server.

3. **Regular Patch Management:**
    - Establish a policy for frequent updates of software and dependencies.

Long-Term Actions

1. **Perform Security Audit:**
    - Engage a professional cybersecurity team to conduct a thorough penetration test.
2. **Train Development Team:**
    - Provide training to ensure secure coding practices and awareness of common vulnerabilities.
3. **Monitor Logs and Alerts:**
    - Set up continuous monitoring to detect and respond to suspicious activities.

---

5. Conclusion

These findings suggest the UNEB E-PAY platform faces risks that could jeopardize its integrity and security. I strongly recommend prioritizing the outlined actions to mitigate these risks and secure the platform effectively. If additional information or assistance is required, I am happy to collaborate further.

Thank you for addressing these important concerns.

Sincerely,
William Moru
Cybersecurity Engineer | Certified Ethical Hacker | Senior Software Tester (app security)
Email:moruwilliam7@gmail.com
Phone: +256772207013